Secure Sockets Layer

Session 10



For Aptech Center Use Only

Version 1.0 © Aptech Limited.

Objectives

- *Explain the working of SSL protocol*
- *Explain the use of SSL module*
- *Explain the installation process of a private key*
- *Explain the creation of a certificate-signing request and a temporary certificate*

For Aptech Center Use Only

Secure Sockets Layer (SSL)

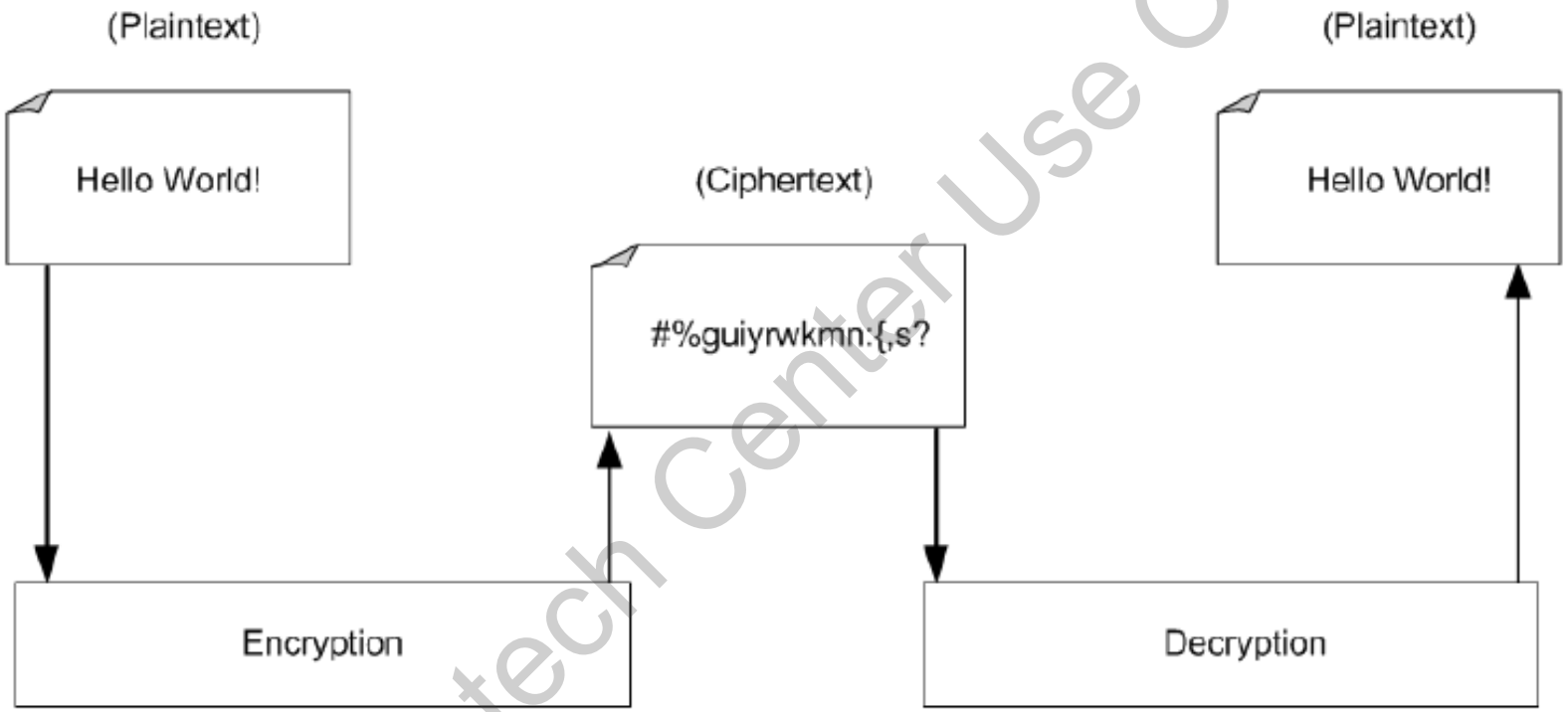
- Used for secure communication over the Internet
- Defines an encrypted link between a Web server and a browser to ascertain that the transmitted data remains confidential
- The main objectives of an SSL are as follows:
  - Authenticating the client and server communication with each other
  - Ensuring data security and integrity

For Aptech Center Use Only

Cryptography

- Process of converting data into scrambled code, transmitting it across a given network, and deciphering it at the other end
- The encrypted message is known as cipher text and the receiver can decrypt it by using a secret key at the receiving end
- Cryptography forms are as follows:
  - Symmetric cryptography
  - Asymmetrical cryptography

For Aptech Center Use Only

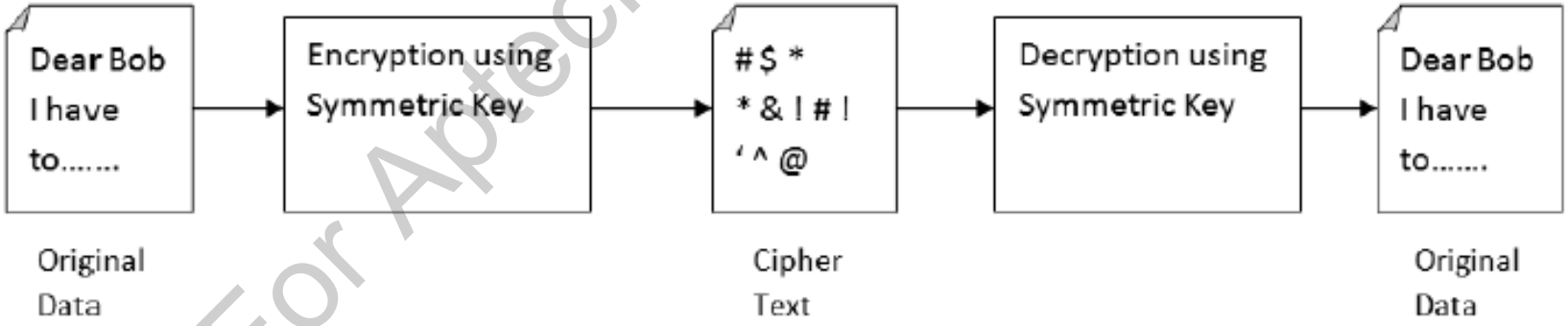


Cryptographic Algorithm

For Aptech Center Use Only

Symmetric Cryptography

- Use the same key for encryption and decryption of message or a communication system
- Key is a secret piece of information and is used for encryption and decryption
- Can be used only if the key is available to both the parties involved in the communication
- If the key is hacked, then the encrypted message can be decrypted, modified, and again encrypted using the same key



For Aptech Center Use Only

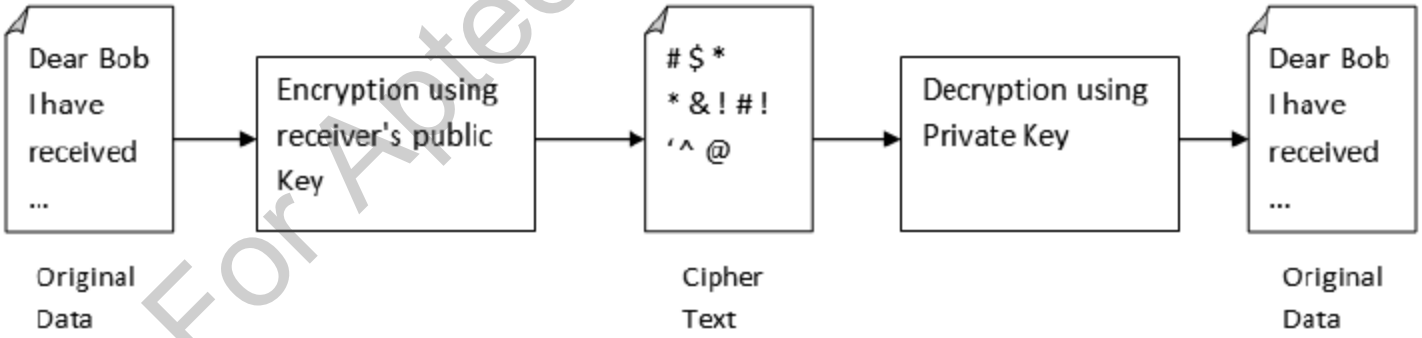
Symmetric Cryptography

- Advantages
  - Fast mode of encryption
  - Can be used with large amounts of data
- Disadvantages
  - Can be hacked and decoded unless you have carefully planned the coding
  - Mandatory for both the participants to know the single key being used

For Aptech Center Use Only

Asymmetric Cryptography

- Uses two different keys for encryption and decryption
- Each machine involved in the communication must hold a pair of keys that are as follows:
  - A public key - published on the network
  - A private key - applicable only to the machine
- A message encrypted with a public key can be decrypted using only the private key corresponding to that public key



For Aptech Center Use Only

Message Digest

- Provide a reliable method to ensure message integrity
- Converts a plain text message into a short, fixed-length string (hash)
- Any change to the text message modifies the corresponding message hash
- Act as a digital fingerprint of the original message

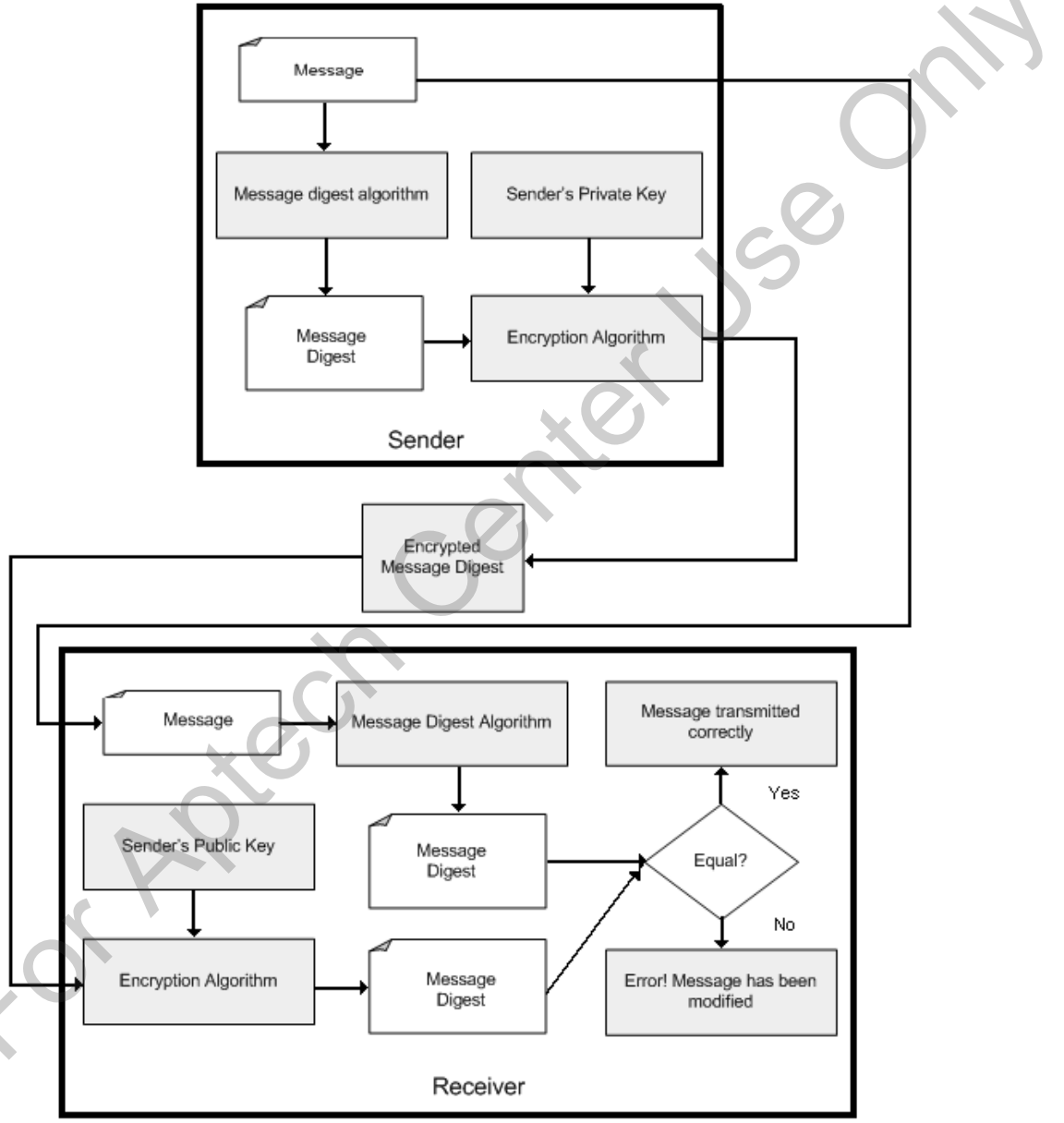
For Aptech Center Use Only

Message-Digest Algorithm 5 (MD5)

- Cryptographic hash function that contains a 128-bit (16-byte) hash value
- Integrity of data is verified by transmitting the summary along with the data
- Receiver calculates a summary of its own from the received message and compares it with the received summary
- If the two summaries match exactly, then it implies that the message was received intact

For Aptech Center Use Only

Message Digest System



For Aptech Center Use Only

Digital Signatures

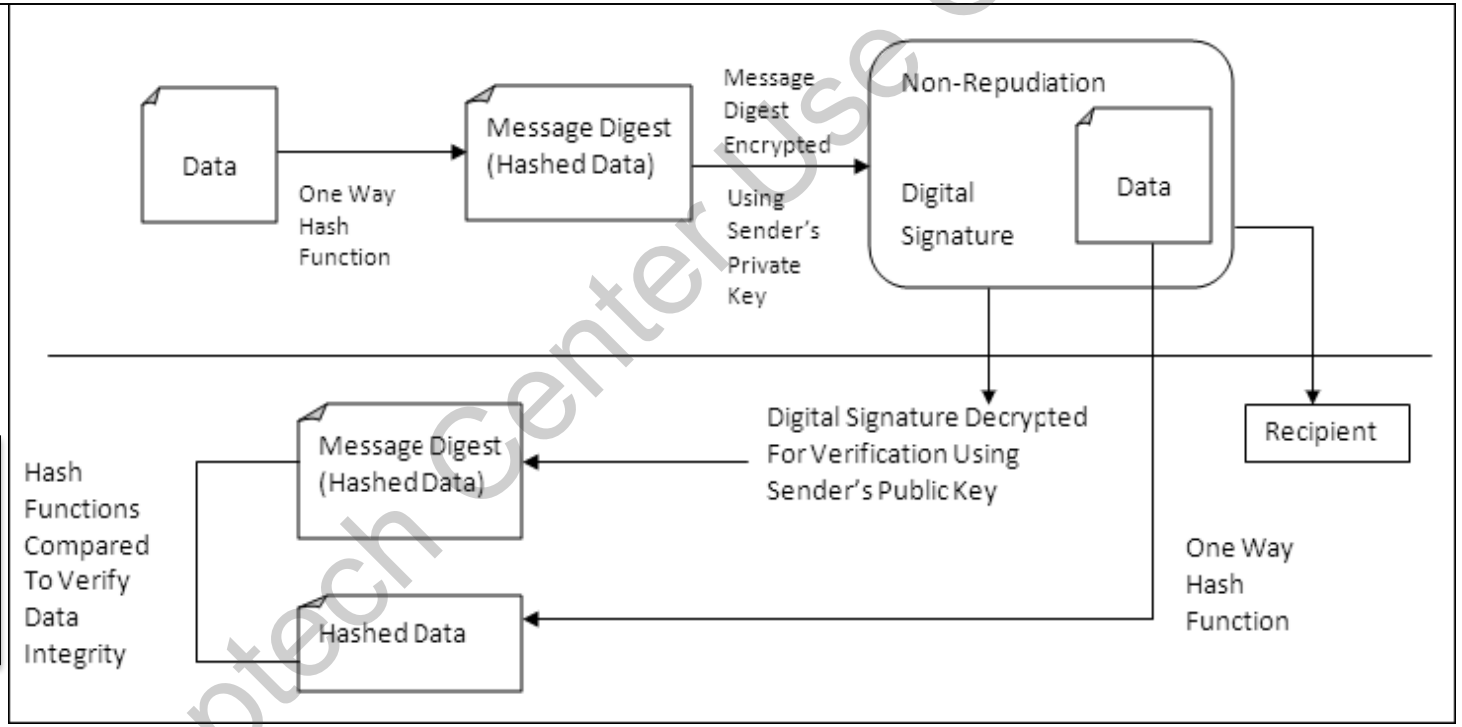
- Created by encrypting the message digest with the sender's private key
- Assures the recipient about the credibility of the user and the integrity of the message
- Used to implement electronic signatures but not all electronic signatures use digital signatures
- Algorithms:
  - Key Generation Algorithm
    - Selects a private key and transmits a corresponding public key
  - Signing Algorithm
    - Generates a signature for a given message and private key
  - Signature Verifying Algorithm
    - Authenticates a given message using the public key and the signature

For Aptech Center Use Only

Digital Signature System

Encryption process

Decryption process



For Aptech Center Use Only

Digital Signature System

1. Sender transmits the encrypted data with the key generated by the Message Digest, and the corresponding hash is generated
2. Encrypted data is Validated using digital signature which ensures authentication, integrity, and non-repudiation
3. The hashed data and digital signature is sent to the receiver along with the sender's public key
4. Both the data are compared to ensure that the integrity of the data is maintained

For Aptech Center Use Only

SSL Protocol

- Ensures privacy and integrity between two communicating applications using TCP/IP
- Runs above TCP/IP and below higher-level protocols, such as HTTP or IMAP
- Permits:
  - Authentication of an SSL-enabled server to an SSL-enabled client
  - Authentication of the client to the server
  - Establishment of an encrypted connection between the client and the server
- Types:
  - SSL Record Protocol
  - SSL Handshake Protocol

For Aptech Center Use Only

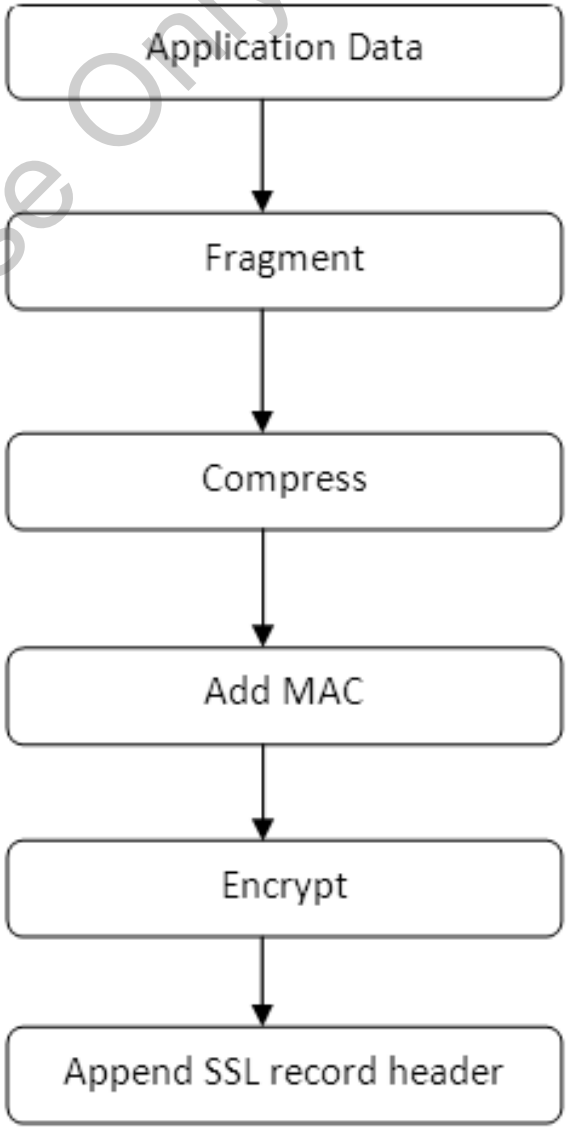
SSL Record Protocol

- Specifies the format for data transmission and handles the encryption for all messaging
- Consist of the encapsulated data, digital signature, message type, version, and length
- Provides:
  - Confidentiality
  - Message Integrity

For Aptech Center Use Only

SSL Record Protocol

1. Accepts the message to be transmitted
2. Breaks up the data into smaller blocks
3. Compresses the data (this step is optional)
4. Applies a Media Access Control address (MAC address)
5. Encrypts the data
6. Adds a header
7. Transmits the resulting unit in a TCP segment
8. Decrypts, verifies, decompresses, and reassembles the received data and delivers it to the calling application



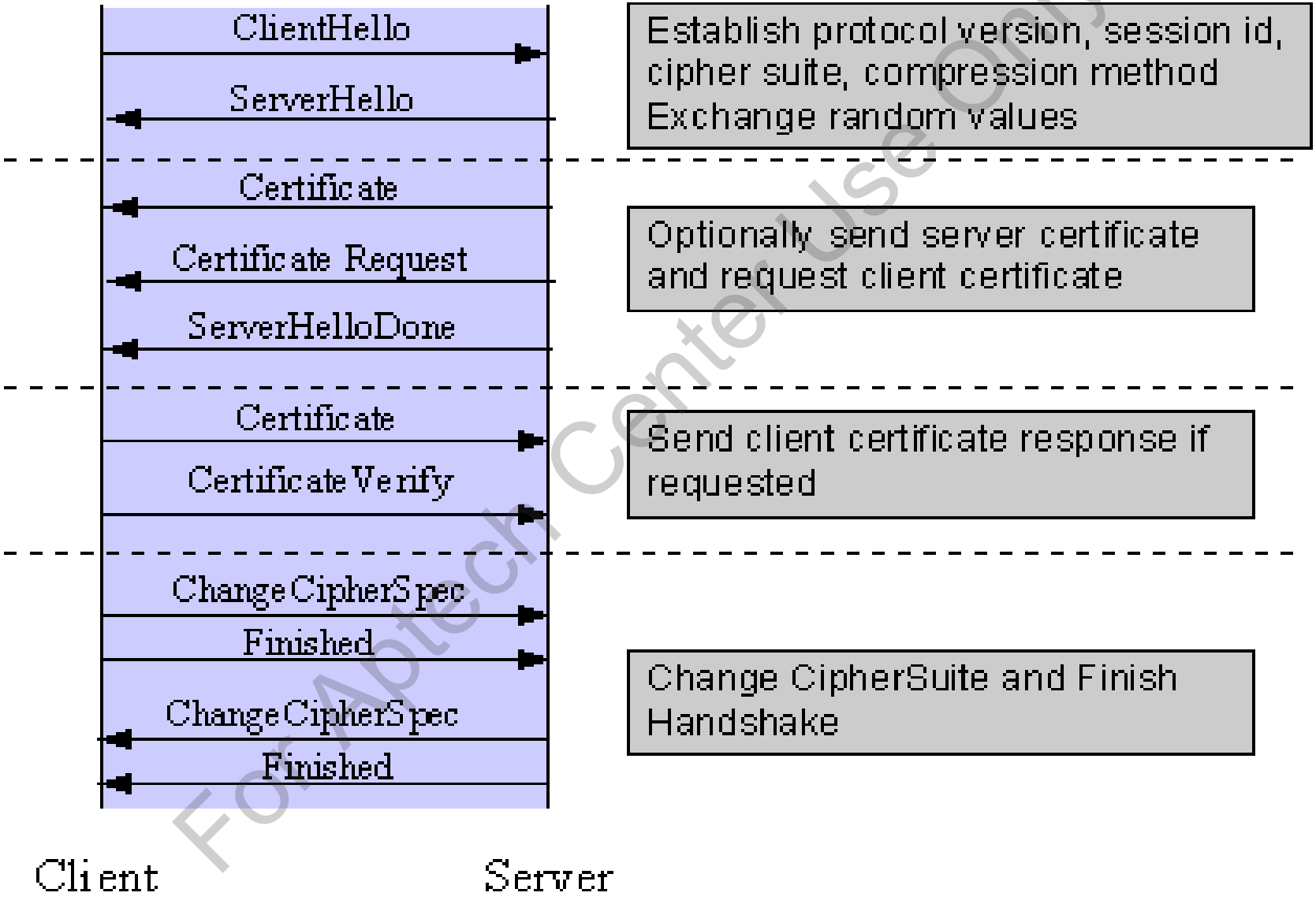
For Aptech Center Use Only

SSL Handshake Protocol

- Process where the client and the server exchange information and negotiate services
- Uses the SSL record protocol to exchange messages between an SSL-enabled client and SSL-enabled server when an SSL connection is established
- An HTTP-based SSL connection is always initiated by the client using a URL starting with `https://` instead of `http://`
- At the beginning of an SSL session, an SSL handshake is performed, which produces the cryptographic parameters of the session

For Aptech Center Use Only

SSL Handshake Protocol



For Aptech Center Use Only

Directives Provided In mod_ssl Module

- `SSLCertificateFile` Directive
- `SSLCertificateKeyFile` Directive
- `SSLCertificateChainFile` Directive
- `SSLEngine` Directive
- `SSLProtocol` Directive
- `SSLVerifyClient` Directive

For Aptech Center Use Only

SSLCertificateFile Directive

- Specifies the location of the server certificate

Syntax

```
SSLCertificateFile filepath
```

Snippet

```
SSLCertificateFile
/usr/local/apache2/conf/ssl.crt/server.crt
```

For Aptech Center Use Only

SSLCertificateKeyFile Directive

- Specifies the location of the private key file of the server
- Used if the private key is not stored in the server certificate

Syntax

```
SSLCertificateKeyFile filepath
```

Snippet

```
SSLCertificateKeyFile
usr/local/apache2/conf/ssl.key/server.key
```

For Aptech Center Use Only

SSLCertificateChainFile Directive

- Specifies the location of the certificate chain file
- This file consists of a list of accepted CA, ranging from the issuing CA certificate of the server certificate to the root CA certificate
- Such a file just joins the various PEM-encoded CA certificate files, usually in certificate chain order

Syntax

```
SSLCertificateChainFile filepath
```

Snippet

```
SSLCertificateChainFile
usr/local/apache2/conf/ssl.crt/ca.crt
```

For Aptech Center Use Only

SSLEngine Directive

- Enables or disables the SSL protocol engine
- It is generally used inside a `<Virtual Host>` section to enable SSL for a specific virtual host

Syntax

```
SSLEngine on|off
```

Snippet

```
<VirtualHost _default_:443>
  SSLEngine on
  …
</VirtualHost>
```

For Aptech Center Use Only

SSLProtocol Directive

- Controls which versions of the SSL protocol will be accepted in new connections

Syntax

```
SSLProtocol   [+ | -] protocol
```

where,

- protocol – specifies a particular protocol
- **SSLv2** - Original SSL protocol designed by Netscape and represents the SSL protocol version 2
- **SSLv3** - Represents the SSL protocol version 3 and is supported by most browsers
- **TLSv1** - Represents the Transport Layer Security protocol, version 1.0 and is the successor to SSLv3, but not yet supported by any popular browsers
- **All** - Represents all the above protocols
- **+** - Includes the specified protocol
- **-** - Excludes the specified protocol

Snippet

```
SSLProtocol all -SSLv3
```

For Aptech Center Use Only

SSLVerifyClient Directive

- Specifies the certificate verification level for client authentication

Syntax

```
SSLVerifyClient level
```

For Aptech Center Use Only

Generation of Private Key

- Two types of private keys can be generated namely,
  - RSA
  - Digital Signature Algorithm (DSA)
- Passphrase (the protecting password) needs to be specified, each time you start Apache server

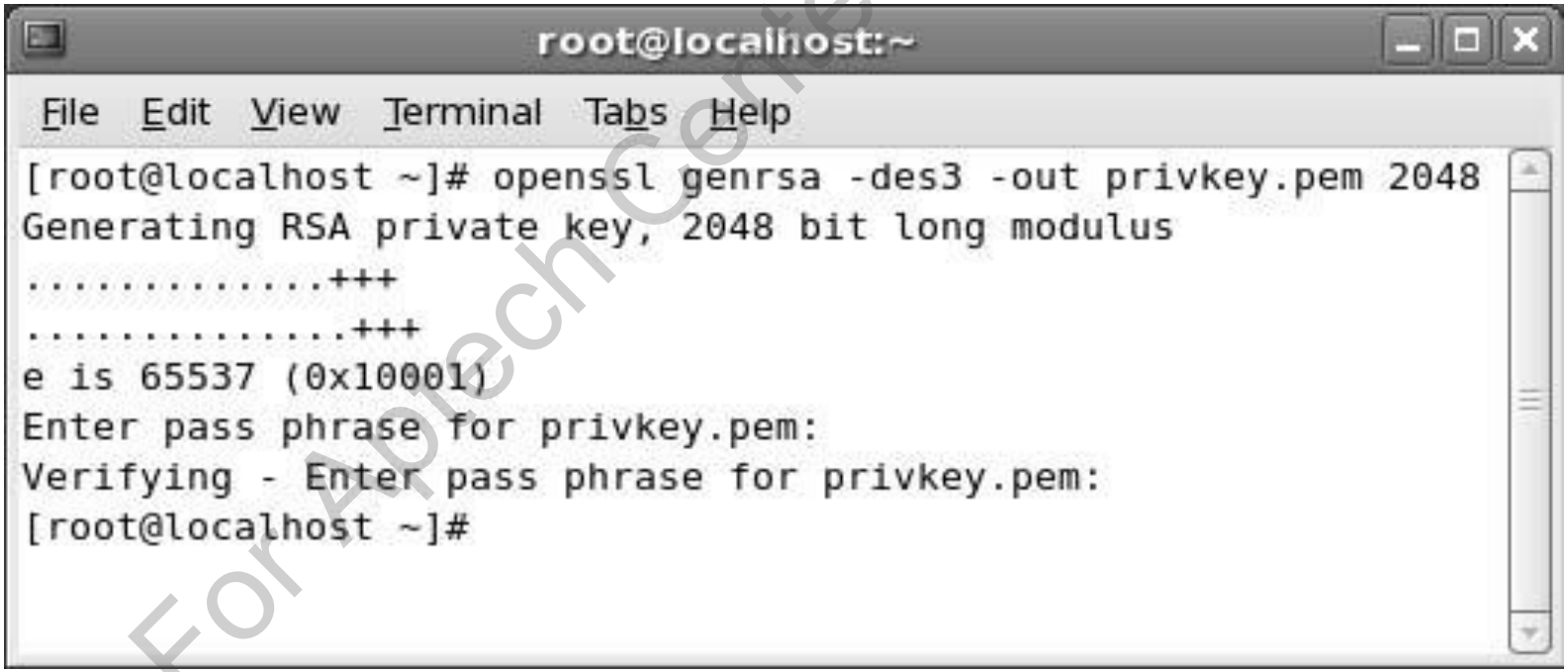
For Aptech Center Use Only

Generation of RSA key

- This command creates a 2048-bit RSA key and stores it in the file `privkey.pem`

Snippet

```
openssl genrsa -des3 -out privkey.pem 2048
```



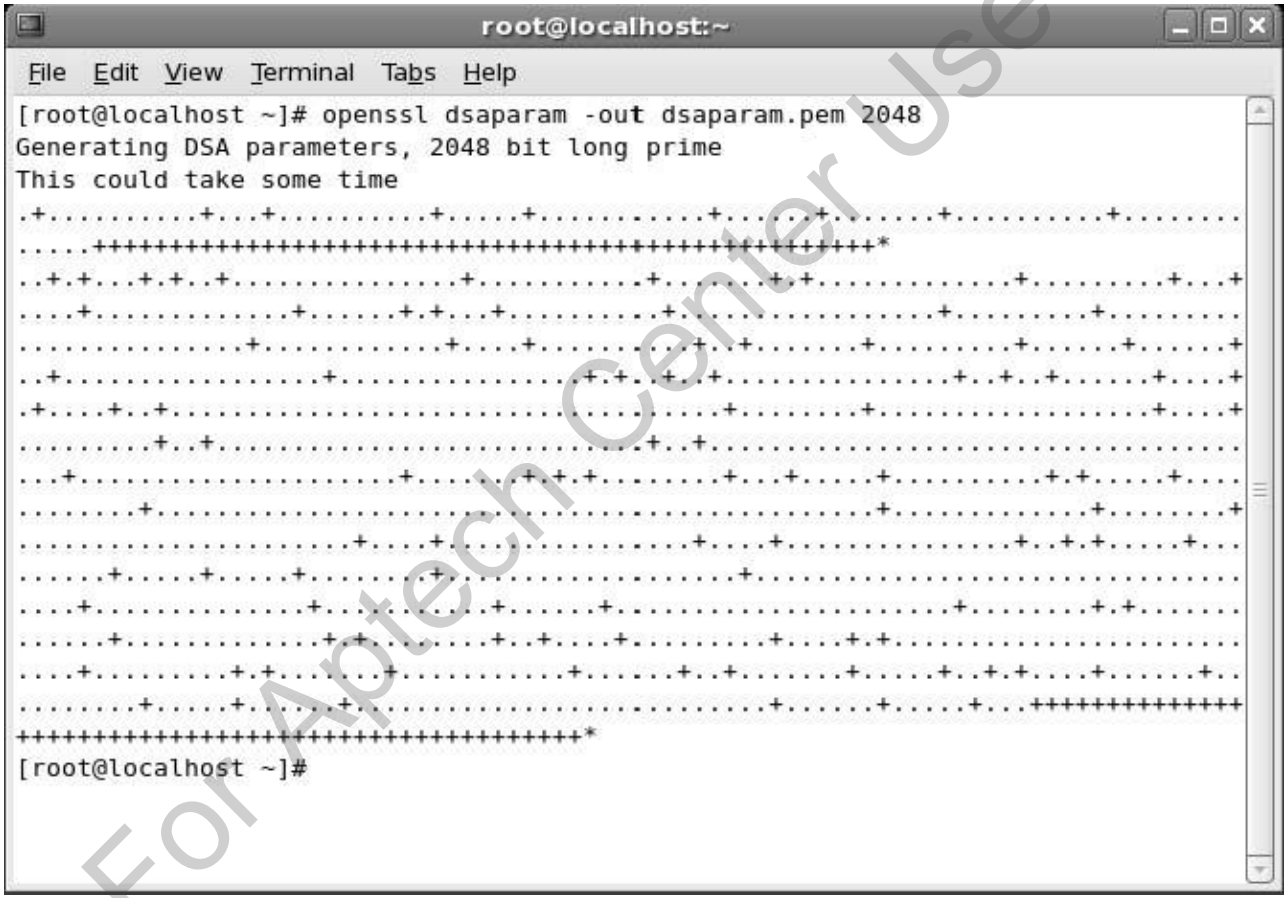
Output

For Aptech Center Use Only

Generation of DSA key for Signing

Snippet

```
openssl dsaparam -out dsaparam.pem 2048
```



Output

For Aptech Center Use Only

Generation of DSA key

- After generating the DSA key, enter the following command to generate a key using DES3 encryption

Snippet

```
openssl gendsa -des3 -out privkey.pem dsaparam.pem
```



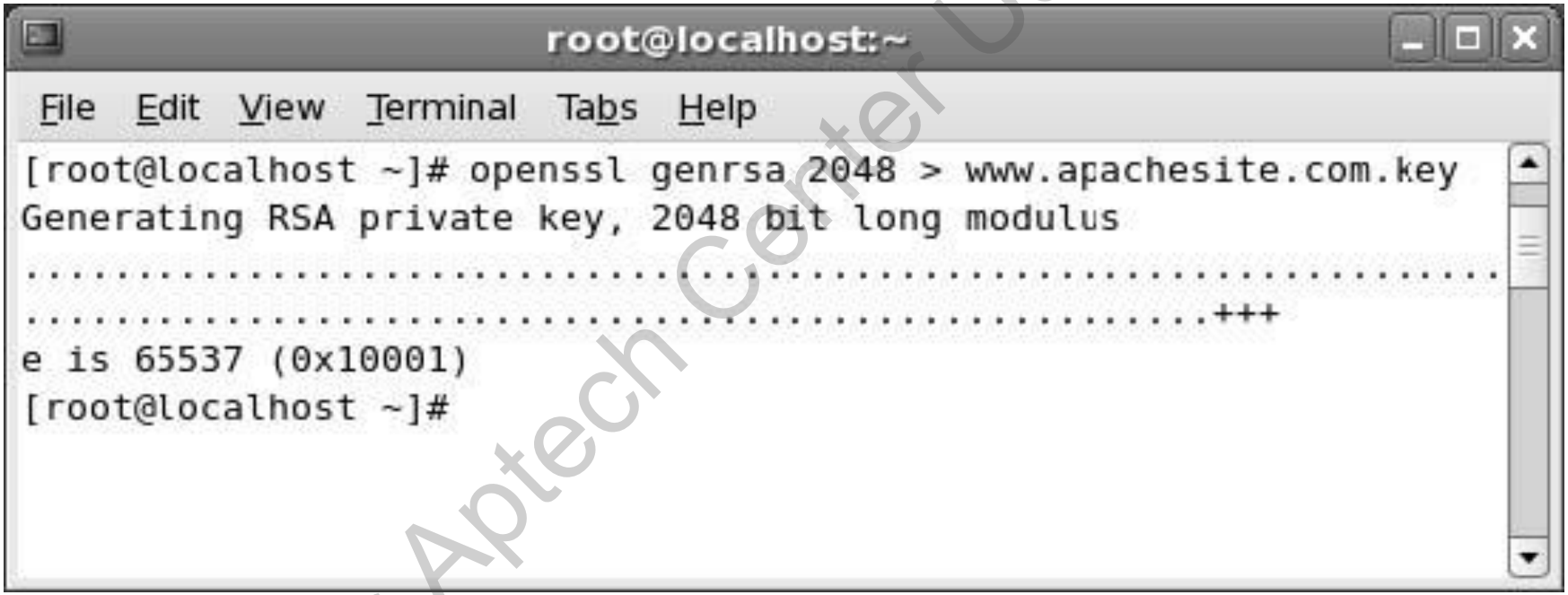
Output

For Aptech Center Use Only

Generation of Unencrypted Private Key

Snippet

```
openssl genrsa 2048 > www.apachesite.com.key
```



Output

For Aptech Center Use Only

Certificates

- Establishes credentials for any online transactions
- Contains information, such as:
  - Distinguished name
  - Public key of the applicant
  - Signature of the Certification Authority (CA)
  - Period of validity
- Validates the authenticity of the two systems that communicate with each other
- Required to validate a private key
- To verify the authenticity of a certificate, it has to be digitally signed
- A digitally signed certificate cannot be modified
- Can be created and signed by using the OpenSSL utility

For Aptech Center Use Only

Certificate Signing Request

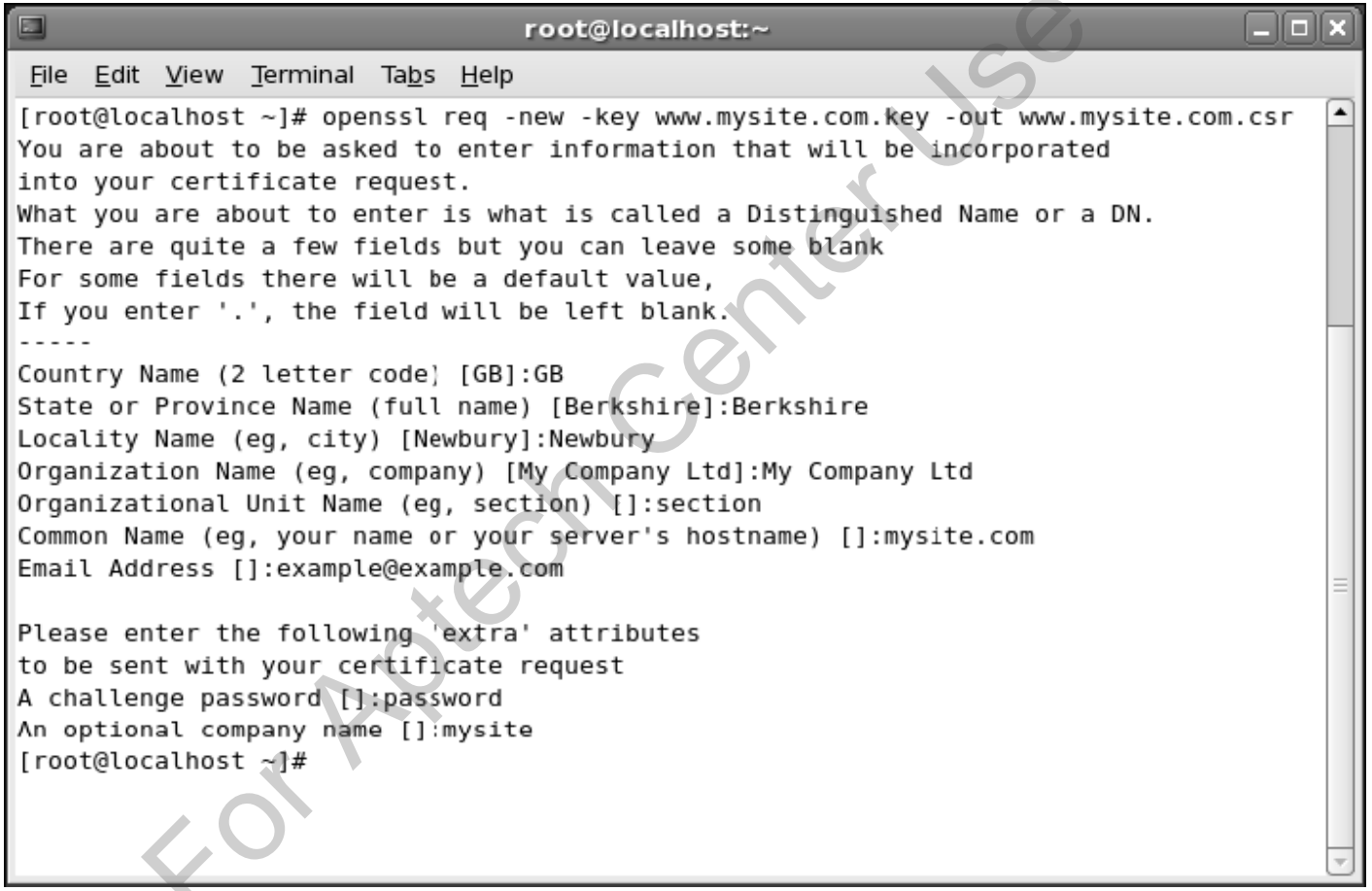
- Application sent from an applicant to a CA to acquire a digital identity certificate
- The applicant generates a key pair that includes the public key and the private key
- The CSR is then generated that contains information, such as:
  - Owner name
  - E-mail address
  - Certificate usage
  - Duration of validity
  - Public key
- Private key is not included in the CSR. However, the private key is used to digitally sign the request
- After verifying the credentials, the CA sends a digitally signed identity certificate to the client along with its private key

For Aptech Center Use Only

To Generate A CSR

Snippet

```
openssl req -new -key www.mysite.com.key -out www.mysite.com.csr
```



Output

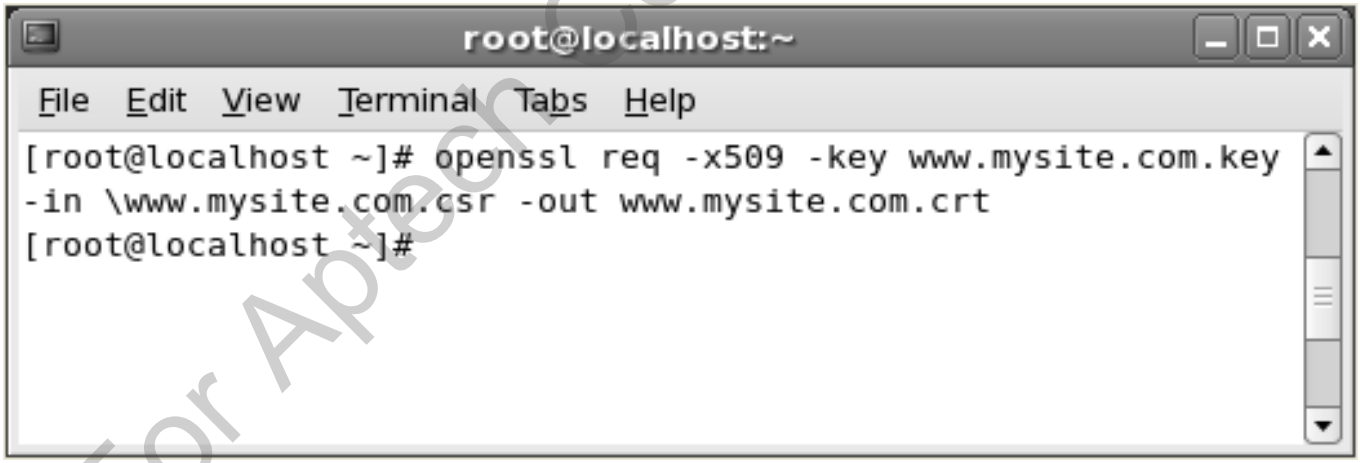
For Aptech Center Use Only

Temporary Certificate

- Will generate an error in the client browser specifying that the signing CA is unknown and not trusted
- To create a temporary certificate, after generating a CSR, enter:

Snippet

```
openssl req -x509 -key www.mysite.com.key -in \www.mysite.com.csr -out
www.mysite.com.crt
```



Output

For Aptech Center Use Only

View The Contents of Temporary Certificate File

Snippet

```
vi www.mysite.com.crt
```



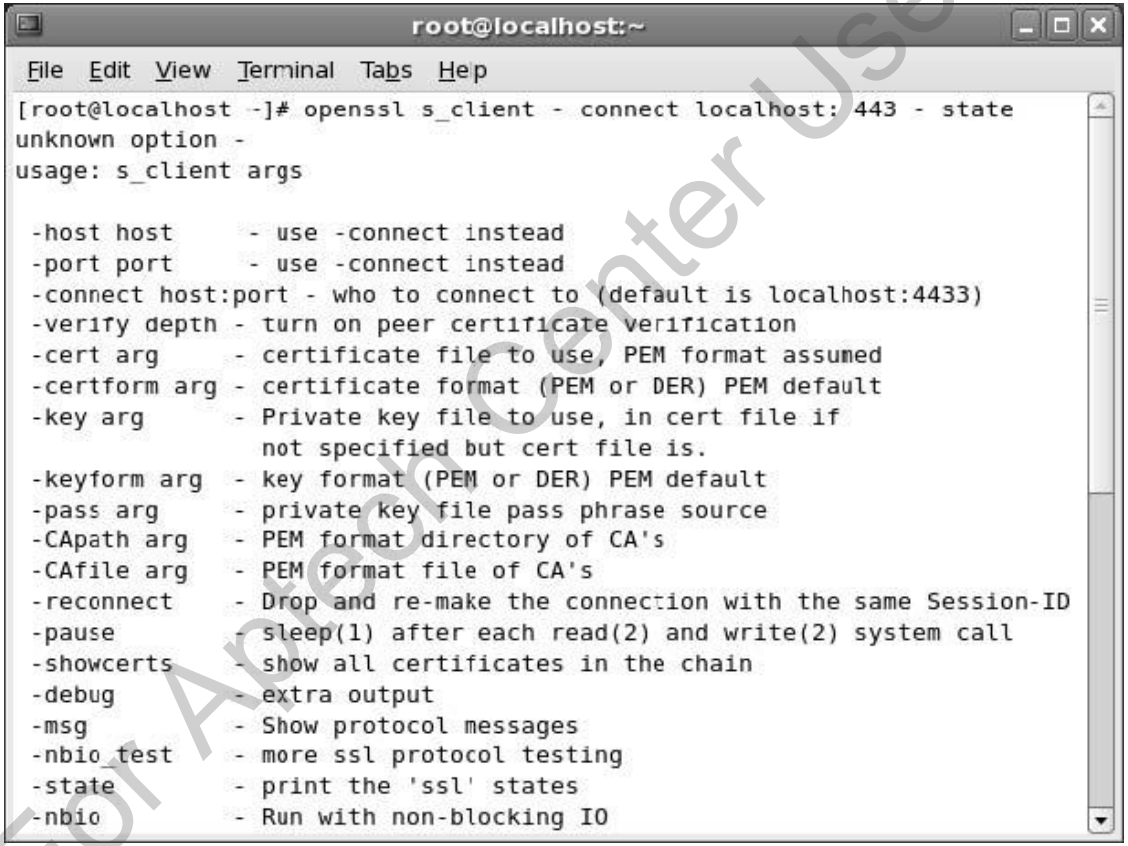
Output

For Aptech Center Use Only

Testing SSL Connection

Snippet

```
openssl s_client – connect localhost: 443 – state
```



Output

For Aptech Center Use Only

Acquiring Signed Certificate

- Verisign and Thawte are two recognized companies that issue digital certificates
- The following information is required to receive a digitally signed certificate:
  - Proof of ownership for the organization name mentioned in the CSR
  - Proof of ownership of the domain name specified in the CSR
  - Proof of authorization of the requesting party
  - CSR file
- After authentication and verification, the Certification Authority issues a digitally signed certificate

For Aptech Center Use Only

Summary

- The SSL protocol establishes a secure connection between a client and a Web server
- Encryption is the method of converting a source message into an unreadable format before transmission. The encrypted message is also known as cipher text
- A message digest is formed by transforming the original message with the help of a one-way hash function
- A digital signature is created by encrypting the message digest with a private key
- A certificate is an electronic document used for the identification of a person, a server, or a company

For Aptech Center Use Only